CERT – Case Evidence Review Tracker

Demonstrator Guide

IS4234 Governance, Regulation and Compliance Technology · NUS, AY2026/27 Semester 1
Group: **[Group ID]**
Hosted demonstrator: **[hosted link to be added]**
Prepared 02 November 2026

Student name	Matriculation number
Glen Tan Lusheng	A0309283B
Loh Kai Kiat Keith	A0308908W
Tan Yi Long	A0308902H

A technology demonstrator for the Post Office Horizon case. All people, branches and records in the prototype are fictional.

1. Purpose of the prototype

CERT (Case Evidence Review Tracker) is a compliance-monitoring workflow built for the Post Office Horizon case (focus period 2010–2015). Post Office Limited (POL) held information suggesting that Horizon could be wrong, but no dependable mechanism carried that information to someone with the independence and authority to stop a decision against a subpostmaster (SPM). CERT provides that mechanism. It:

- brings case data and supplier-held technical records (PEAKs, KELs, ARQ audit data, remote-intervention logs) together, keeping each record's original ID, source file, receipt time and SHA-256 hash;
- shows which required evidence is Complete, missing (Gap) or uncertain (Unknown);
- flags potentially relevant defects and explains which fields matched;
- assigns follow-up tasks and escalates delay;
- **blocks reliance on disputed figures** (issuing a recovery demand, or passing figures on as reliable for prosecution or disclosure) until required inquiries are complete and an independent reviewer with no prior involvement has recorded a reasoned decision; and
- re-screens every case, open and closed, whenever a new or updated defect record arrives.

CERT does not decide causation, guilt or disclosure. A defect link is a reason to inquire, not proof. A non-match is labelled *no known defect identified*, never "Horizon reliable". All people, branches and records in the demonstrator are fictional.

2. Intended users

User	Decision supported in CERT
Investigator	What evidence is still needed; which defects require inquiry
Supplier liaison manager	Whether requested supplier data was delivered and covers the disputed period
Technical reviewer	Whether an expert statement addresses the linked PEAKs and KELs
Independent legal reviewer	Whether material must be disclosed, whether reliance may proceed, whether earlier decisions need referral
Legal lead (control owner)	How to resolve overdue work and escalated concerns; authorising exceptions only when uninvolved
Internal audit / Audit & Risk Committee	Whether controls are operating; where corrective action is required

3. The GRC problem and the decisions CERT supports

The report traces how information about a Horizon defect should have travelled from Fujitsu's records to a decision about an individual SPM, and where it broke. CERT targets three of the root causes identified there:

- **RC2 – No owner of the evidence chain.** Fujitsu held PEAKs, KELs and audit data; investigators used management information; lawyers assessed disclosure. Nobody owned the connection between them. CERT links each defect record to every case it could affect and gives each open question a named owner and a deadline.

- **RC3 – Weak evidence access and preservation.** Audit data was requested selectively and there was no case-file retention policy. CERT checks evidence coverage against the full disputed period, keeps every source record with a hash, and records each change in an append-only, hash-chained audit log.
- **RC5 – Oversight of outputs, not controls.** The board was told POL had "won every criminal prosecution". CERT's dashboard reports whether controls are operating (gaps, overdue links, exceptions, self-review attempts, supplier delays), not how many cases were won.

These causes were amplified by the legal presumption that computers operate correctly, which left the SPM to prove a fault using records only Fujitsu held. CERT's reliance gate reverses that default inside the organisation: unresolved doubt stops reliance until an independent person has addressed it. The table below shows how each obligation maps to a CERT control (report Table 4.5).

Obligation	CERT control	Evidence produced
Reasonable inquiry (CPIA Code)	C1 Coverage checklist and reliance gate (Rules 2–3)	Coverage checklist; gap register
Disclosure (CPIA s. 3)	C2 Defect linking and independent review (Rules 1, 3)	Explained links; review decision
Record retention (CPIA Code)	C3 Versioned, hashed source records	Source versions; change log
Post-conviction duty (common law)	C4 Reassessment (Rule 5)	Case screening tasks
Expert duties to the court	C5 Expert completeness check (Rule 2)	Check, omissions, corrections
Board oversight (COSO; Three Lines)	C6 Escalation and KRIs (Rule 4)	Alerts, dashboard, audit samples

4. Main functions and workflow

A case moves through seven stages, shown as a stepper at the top of every case:

1. **Register** the case and the SPM's explanation.
2. **Link defects** (Rule 1). A potential link is flagged only when the branch is in the defect's scope, the defect's *affected* period overlaps the disputed period, and the Horizon version is compatible. Matching uses the affected period, not the date the defect was reported, so a defect discovered later still links to earlier cases. Any Unknown field sends the pair to a manual-review queue instead of discarding it.
3. **Check coverage** (Rule 2): ARQ audit data for the full disputed period, remote-intervention logs, the defect-search result, the SPM's explanation and any expert statement relied on. Partial coverage is a Gap and creates a retrieval task for the supplier liaison manager.
4. **Investigate** flags, reasonable alternatives and expert completeness. A technical reviewer checks whether the expert statement addresses every linked defect; omissions open a correction task. Missing evidence returns a case to this stage.
5. **Review independently** (Rule 3). The reviewer declares no prior involvement and records a decision with reasons. Self-approval, open inquiries and incomplete expert checks block reliance, and every blocked attempt is logged. If the evidence changes after a review, a fresh review is required.
6. **Escalate** at any stage (Rule 4). Undermining material, or a legal deadline within 5 working days, goes to the legal lead immediately; routine delay goes to the legal lead at 10 and the Audit & Risk Committee at 20 working days. These are proposed service standards, not statutory periods.

7. **Reassess** (Rule 5). A new or updated defect record re-runs Rule 1 against every case, open and closed, regardless of date. Reassessment tasks link to the original decision, which is preserved unchanged.

Unavailable evidence. After documented reasonable retrieval, a reviewer may propose an exception recording the gap, its implications and an action-specific step. It needs confirmation that duties are met and separate authorisation by an uninvolved legal lead or external legal reviewer. It never bypasses an open required inquiry, and the gap stays visible.

Screens

Screen	What it shows
Case list	All cases with stage, gate status, open gaps, open inquiries and escalation; manual-review queue; the current user's tasks; case registration
Case view	Header, workflow stepper, gate banner stating why reliance is blocked, evidence coverage, defect links, expert check, tasks and escalations, review form, reliance actions and exceptions, supplier evidence, helpline records, case history, evidence-index export
Defect records	PEAKs and KELs; upload by CSV or form; Rule 5 results ("X reassessment tasks created")
Oversight dashboard	Report Table 4.4 KRIs with RAG status and "escalates to"; current escalations; gate-attempt counts
Audit log & integrity	Filterable append-only log; Verify hashes; Verify audit-log chain
About & limitations	Purpose, roles, rules and limitations

5. Software, platform and tools

- **Python** (3.11 or later), **Streamlit 1.66** (web interface), **SQLite** (database, built into Python), **pandas 3.1** (tables) and **pytest 9.2** (tests). Exact versions are pinned in `requirements.txt`.
- Hosting: **Streamlit Community Cloud**, deployed from a public GitHub repository.
- The rules are transparent Python functions (`rules.py`), not machine learning, so reviewers can see exactly why a link was flagged, and because no validated training dataset of PEAKs, KELs and case outcomes exists.
- Code structure: `app.py` (entry point), `pages/` (screens), `rules.py` (Rules 1–5, no user interface), `services.py` (workflow and audit logging), `db.py` (schema, hashing, audit chain), `seed.py` (synthetic data), `evaluation.py` and `tests/` (tests and metrics).
- Built with assistance from Claude Code (see the AI acknowledgement in the report).

6. Accessing, opening and running the prototype

Option A – Hosted (recommended). Open **[hosted link to be added]** in a current browser (Chrome, Edge, Safari or Firefox). No account or installation is needed. The hosted database is shared by all visitors, so press **Reset demo data** in the sidebar first to see the seeded state.

Option B – Run locally. From the project folder:

```
python -m venv .venv
.venv\Scripts\activate            # macOS/Linux: source .venv/bin/activate
pip install -r requirements.txt
streamlit run app.py              # opens http://localhost:8501
```

On first run CERT builds `data/cert.db` from the synthetic seed in a few seconds. To rebuild it at any time, press **Reset demo data** in the sidebar or run `python seed.py`.

Running the tests. `python evaluation.py` runs the test suite (one test per row of report Table 4.6, plus integrity and page-render tests), computes recall, precision and gate enforcement, and writes `test_results.md`. `pytest -q` runs the tests alone.

7. Installation and system requirements

- **Hosted:** any modern browser; a screen at least 1280 px wide is recommended because case pages use wide tables.
- **Local:** Windows, macOS or Linux; Python 3.11 or later; an internet connection for the one-off `pip install`; about 400 MB of disk space for dependencies. No database server or other services are needed.

8. Test data and demonstration accounts

There are no passwords. The sidebar **role switcher** selects a role and a named user, standing in for a login. Every record is synthetic. The **demo clock** in the sidebar defaults to **18 Nov 2013** and can be moved forward to watch escalations trigger.

Role	Named users
Investigator	A. Tan, R. Shah
Supplier liaison manager	M. Okafor
Technical reviewer	S. Patel
Independent legal reviewer	J. Lim, K. Wong, E. Clarke (external)
Legal lead (control owner)	D. Morgan
Internal audit / Audit & Risk Committee	H. Ng

Case	Scenario
C014	Report Section 4.2.6 (main walkthrough below)
C001	Fully clear case: complete evidence, no known defect identified, gate CLEAR
C003	Closed 2008 Legacy Horizon case caught by a defect loaded in 2013
C005	Self-approval attempt by the involved investigator, blocked and logged
C006	ARQ request open 25 working days, escalated to the Committee; rejected exception attempt
C007	Legal deadline 3 working days away, escalated immediately; remote-intervention logs Unknown
C008	Horizon version Unknown, sent to the manual-review queue
C009	Unavailable evidence: exception validly authorised, gap still visible, gate CLEAR
C010	Exception authorisation by a conflicted legal lead rejected and escalated

Case	Scenario
C011	Closed case caught when KEL-D07 is loaded

Sample upload files are in `sample_data/`: `KEL-D07_later_defect.csv` (the later defect record used in the walkthrough) and `defects_seed_extract.csv` (the seeded defects, showing the CSV format).

Suggested walkthrough (about 10 minutes, case C014)

1. **Case list:** C014 shows BLOCKED with open gaps and an escalation to the legal lead. Select it.
2. **Case view header:** £4,200 disputed over 1 Apr – 12 May 2013 (six weeks), Horizon Online v2, Stage 4 Investigate.
3. **Gate banner:** reliance is blocked because the ARQ data covers only 4 of 6 weeks, the expert statement omits KEL-D01, and independent review RV-005 referred the material to the prosecutor.
4. **Evidence coverage:** ARQ audit data is a Gap, with retrieval task T-022 assigned to M. Okafor.
5. **Defect links:** KEL-D01 is linked on branch, affected period and version, although it was reported on 9 Sep 2013, after the disputed period. KEL-D02 is not linked because it affects a different Horizon version.
6. **Expert check:** XC-001 records the omission of KEL-D01 and correction task T-025 for S. Patel.
7. **Reliance & exceptions:** as A. Tan, press *Issue recovery demand*. It is blocked and the reasons are logged.
8. **Independent review tab:** J. Lim's conflict declaration and decision are recorded against evidence v7.
9. **Self-approval:** switch to Investigator R. Shah, open C005 and try to record a review. It is blocked and logged as a self-review attempt.
10. **Rule 5:** switch to Supplier liaison manager, open *Defect records* and load KEL-D07 (one-click demo tab or CSV upload). CERT re-screens all cases and creates two reassessment tasks: for C014 (linked to decision RV-005) and for closed case C011.
11. **Dashboard:** KRIs show red and amber status with escalation targets. Move the demo clock forward to watch routine items escalate.
12. **Audit log:** press *Verify hashes* (all Unchanged), run the demo-only simulated out-of-band edit, then *Verify hashes* again: the edited record shows ALTERED. *Verify audit-log chain* confirms the log is intact.

Test evidence

`test_results.md` records the outcome of every test condition in report Table 4.6 (all nine passed) and the evaluation metrics on the synthetic data: recall 100% (5/5 seeded relevant links flagged), precision 83% (5/6), and gate enforcement 100% (38/38 prohibited actions blocked, while 3/3 permitted actions were allowed). Because the cases and expected links were written by the project team, these results show that the rules behave as specified; they cannot establish accuracy on real records.

9. Known limitations and incomplete functions

Limitations of the demonstrator

- **Synthetic data only.** Results cannot establish real-world accuracy.

- **No real authentication.** The role switcher stands in for logins. Production needs identity and role-based access control, data minimisation, encryption, retention rules, tested recovery and independent security testing.
- **Shared hosted database.** All visitors share one database, which other visitors may change or reset; it is rebuilt when the app restarts.
- **User-controlled clock.** The demo clock lets escalations be shown; production needs a trusted time source.
- **Local tamper evidence.** Hashes and the audit-log chain are stored in the same SQLite file, so they detect out-of-band edits to individual records but not someone with full database access rebuilding the whole chain. Production would anchor the chain externally or use write-once storage. A hash also proves only that a record is unchanged since receipt, not that it is true.
- **The gate controls only actions taken in CERT.** Other systems (for example, finance recovery) would need to require a CERT clearance reference before acting, or reliance could bypass CERT.
- **Scope-based matching.** Rule 1 matches on branch, period and version. A defect record with incomplete or wrong scope will not link, and real PEAKs are often unstructured free text.
- **Proposed thresholds.** Escalation thresholds and the 10-working-day supplier evidence schedule are proposals to be validated in a pilot.

Incomplete functions

- **Supplier integration:** supplier records are uploaded as CSV files or entered by form; there is no direct connection to supplier systems.
- **Complaint patterns:** helpline and complaint records are stored and shown per branch, but CERT does not yet analyse them for recurring patterns that might indicate a defect not yet recorded.
- **Disclosure follow-through:** a "Refer to prosecutor" decision is recorded and keeps the gate blocked, but CERT does not yet track receipt or the prosecutor's disclosure decision.
- **Involvement tracking:** the list of people involved in a case is entered at registration; users who later work on the case are not added automatically.
- **Access log:** CERT logs every change, override and administrative action, but not who viewed a record.
- **Notifications:** escalations appear in CERT and on the dashboard; no email or messaging alerts are sent.
- **Disclosure schedules:** the evidence-index export assists, but does not replace, the reviewer's disclosure schedule.
- **Workload metrics:** review time and alerts per reviewer per week are not measured; they need real reviewers in a pilot.